

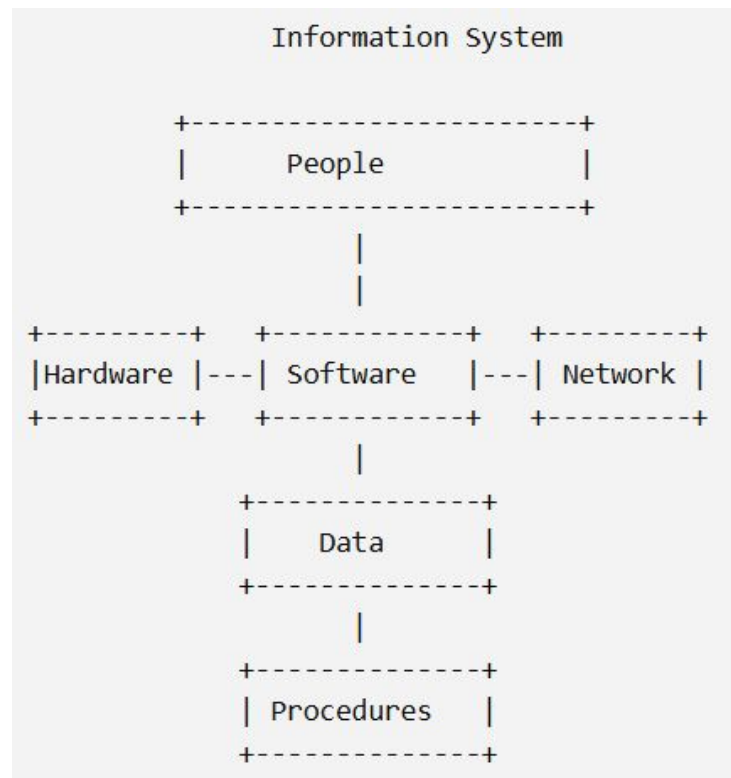
Introduction to Information Systems Security

Introduction

- Information has become one of the most valuable assets of modern organisations. Financial institutions, hospitals, governments, universities, manufacturing industries, airlines, and even individuals rely heavily on information systems for daily operations.
- With increased connectivity through the Internet, cloud computing, mobile technologies, and the Internet of Things (IoT), organisations are more exposed than ever to cyber threats.
- Examples include: ransomware attacks, phishing, insider attacks, data theft, denial-of-service attacks, identity theft
- Consequently, protecting information has become a strategic organisational objective.

What is an Information System?

- An Information System (IS) is a coordinated collection of components that collect, process, store, and distribute information to support decision-making, coordination, control, and business operations.



Explanation of Components

- People: The most important component.
 - Examples: Employees, Managers, Customers, System Administrators, Developers, Hacker (external actors)
 - Humans are often considered the weakest link due to social engineering, poor password practices, and accidental mistakes.
- Hardware: Hardware failures can lead to service interruptions and data loss.
 - E.g. Servers, PCs, Laptops, Routers, Switches, Storages devices
- Software: Software vulnerabilities are a major source of cyberattacks.
 - E.g. OS, DBMS, ERP, Email S/W

Explanation of Components

- Data: Data is often regarded as the most valuable organisational asset.
 - Loss or corruption of data can have severe operational, legal, and reputational consequences.
 - Examples: Student Records, Medical Records, Customer Databases
- Procedures: Procedures define how systems should be used. Well-defined procedures reduce human error and improve consistency.
 - E.g. Backup procedures, Incident Response procedures, Password Policies
- Networks: Networks connect systems and enable communication. Improperly secured networks can become entry points for attackers.
 - E.g. LAN, WAN, Internet

What is Information Security?

- Information Security (InfoSec) is the practice of protecting information and information systems from unauthorized access, disclosure, alteration, destruction, or disruption.
- Information Security is the preservation of Confidentiality, Integrity and Availability while ensuring Authenticity, Accountability, Non-repudiation and Reliability

Why is Information Security Important?

- Information security supports:
 - Business continuity
 - Customer trust
 - Legal compliance
 - Financial stability
 - National security
 - Competitive advantage
- A single breach can result in:
 - Financial loss
 - Operational downtime
 - Regulatory fines
 - Loss of intellectual property
 - Reputational damage

Example

- Suppose a university database is compromised.
- Possible consequences include:
 - Students' grades modified
 - Personal information leaked
 - Examination papers stolen
 - Admission records deleted
 - Payroll altered
- This illustrates the importance of robust information security controls.

CIA Triad

- The CIA Triad is the foundational model of information security.
- **Confidentiality**
 - Confidentiality ensures that information is accessible only to authorised individuals.
- **Integrity**
 - Integrity ensures that information is accurate, complete, and unaltered.
- **Availability**
 - Availability ensures information is accessible when required.



Example

- Confidentiality
 - A lecturer's examination paper should only be accessible by authorised staff.
 - If a student gains access before the examination:
 - Confidentiality has been violated.
 - Mechanisms include: Encryption, Access Control, Authentication, Authorisation, MFA
- Integrity
 - If an attacker changes a student's mark from 62 to 92:
 - Integrity has been compromised.
 - Controls include: Hash functions, Checksums, Digital Signatures, Version Control, Database constraints
- Availability
 - During online registration, students cannot access the university portal because of a Distributed Denial-of-Service (DDoS) attack.
 - Availability has been compromised.
 - Threats include: Hardware Failures, Ransomware, DoS
 - Controls include: Redundant Servers, Backup generator, Load Balancing

Information Assets

- An asset is anything of value that requires protection.
- Examples include:
 - Databases
 - Intellectual property
 - Software
 - Hardware
 - Personnel
 - Reputation
 - Business processes
 - Research data

Threats

- A threat is any event that has the potential to cause harm.
- Examples:
 - Natural threats:
 - Earthquakes
 - Floods
 - Cyclones
 - Human threats:
 - Hackers
 - Insider attacks
 - Malware
 - Espionage
 - Environmental threats:
 - Fire
 - Power outages
 - Water leaks

Vulnerabilities

- A vulnerability is a weakness that can be exploited.
- Examples:
 - Weak passwords
 - Unpatched software
 - Open ports
 - Misconfigured firewalls
 - Poor physical security
 - Lack of security awareness

Risk

- Risk is the likelihood that a threat will exploit a vulnerability and cause harm to an asset.
- A commonly used qualitative relationship is:
 - $\text{Risk} = \text{Threat} \times \text{Vulnerability} \times \text{Impact}$
- For example, an exposed web server (vulnerability) facing frequent internet attacks (threat) and hosting critical student records (high impact) represents a high-risk scenario.

Security Controls

- Security controls reduce risk and are generally classified as:

1. Preventive Controls

1. Firewalls
2. Encryption
3. MFA
4. Security awareness training

2. Detective Controls

1. Intrusion Detection Systems (IDS)
2. Security logs
3. SIEM solutions
4. CCTV

3. Corrective Controls

1. Backups
2. Disaster Recovery Plans
3. Patch management
4. Incident response

Real-World Case Study: WannaCry Ransomware (2017)

- **Background**

- The WannaCry ransomware attack spread globally within hours by exploiting a vulnerability in Microsoft Windows systems. It encrypted users' files and demanded payment in cryptocurrency for decryption.

- **Impact**

- Over 200,000 computers affected.
- More than 150 countries impacted.
- Hospitals, universities, businesses, and government agencies experienced major disruptions.
- Significant financial losses and operational downtime.

- **Lessons Learned**

- Apply security patches promptly.
- Maintain offline and tested backups.
- Segment networks to limit lateral movement.
- Train users to recognize suspicious activity.
- Develop and regularly test incident response and disaster recovery plans.

Summary

- In this lecture, we explored the foundations of Information Systems Security.
- We examined the components of an Information System, the importance of protecting organisational information, and the core principles of the CIA Triad.
- We also introduced the concepts of assets, threats, vulnerabilities, risks, and security controls, illustrating their application through the WannaCry ransomware case study. These concepts provide the foundation for all subsequent topics in the module.